

Manual 18 — GLBA / FTC Safeguards Rule Controlled Implementation

Controlled English master — development

****Series order:**** 18

****Regulatory boundary:**** This manual is implementation guidance. It does not reproduce protected text, does not provide legal advice, and does not extend FTC jurisdiction beyond organizations subject to the FTC Safeguards Rule. Statutory, regulatory, official-guidance, and organizational-practice layers must remain distinct.

1. Purpose, scope, and regulatory layering

Establish a repeatable program for implementing and evidencing safeguards for covered customer information. Maintain a source map that distinguishes GLBA statutory context, 16 CFR Part 314 requirements, FTC amendments/effective dates, official FTC guidance, and internal control choices. Evidence: applicability memo, source register, control inventory, annual scope confirmation. Test: verify every substantive regulatory statement is traceable to the correct source layer.

2. Financial-institution applicability and jurisdiction

Determine whether the organization is a financial institution for FTC Safeguards Rule purposes and whether another GLBA regulator governs the activity. Document business activities, exemptions, regulator ownership, entity boundaries, and legal review triggers. Evidence: applicability analysis and regulator matrix. Reassess after mergers, new products, licensing changes, or regulator guidance changes.

3. Customer-information scope and data inventory

Inventory customer information and systems that collect, process, transmit, or store it. Map data flows, repositories, interfaces, backups, endpoints, SaaS services, and third parties. Assign data owners and retention classes. Evidence: data inventory, flow diagrams, system register, records-of-processing linkage. Test completeness against discovery tooling, contracts, and architecture inventories.

4. Governance and qualified-individual accountability

Designate the accountable qualified individual and define authority, escalation paths, deputies, budget ownership, reporting duties, and interfaces with privacy, legal, audit, risk, and technology. Evidence: charter, role description, RACI, meeting records. Test that assigned authority is operational rather than nominal.

5. Written information security program

Maintain a written program scaled to organizational size, complexity, activities, and sensitivity of customer information. The program should connect governance, risk assessment, safeguards, monitoring, incident response, service-provider oversight, and reporting. Evidence: approved program document, revision log, linked standards, control owners. Review at least annually and after material change.

6. Risk assessment methodology

Use a documented methodology to identify foreseeable internal and external risks, evaluate likelihood and impact, and determine whether existing safeguards are sufficient. Define scoring, risk acceptance criteria, evidence requirements, and reassessment triggers. Evidence: risk methodology, risk register, treatment decisions. Test repeatability by sampling similar systems and comparing ratings.

7. Risk treatment and safeguards selection

Translate risk findings into preventive, detective, corrective, and recovery safeguards. Record control objective, owner, implementation state, evidence source, residual risk, target date, and exception handling. Evidence: treatment plan and control matrix. Test that significant risks have explicit treatment or formally approved acceptance.

8. Asset and system inventory

Maintain authoritative inventories for hardware, software, virtual assets, cloud services, critical applications, network components, and repositories in scope. Include owner, environment, criticality, lifecycle state, and customer-information relevance. Evidence: CMDB/asset register reconciliation. Test for orphaned and unmanaged assets.

9. Data classification and handling

Define handling requirements for customer information across collection, use, storage, transmission, sharing, archival, and destruction. Align classification to access, encryption, masking, DLP, and retention controls. Evidence: classification standard, labeled datasets, handling procedures. Test sample data stores and transfers against assigned classification.

10. Identity and access management

Apply least privilege, role-based or attribute-based access, timely provisioning/deprovisioning, periodic access review, and strong joiner-mover-leaver controls. Evidence: access requests, approvals, review outputs, termination records. Test for dormant, excessive, shared, and unauthorized accounts.

11. Privileged access and authentication

Restrict and monitor privileged identities. Use strong authentication controls appropriate to the environment, including multi-factor authentication where required or justified by risk. Separate administrative and standard accounts. Evidence: PAM logs, privileged inventory, MFA coverage, break-glass records. Test privileged-path coverage and emergency-access review.

12. Encryption and key management

Protect customer information in transit and at rest using appropriate cryptographic controls or formally documented compensating protection where permitted and justified. Manage keys through defined generation, storage, rotation, revocation, backup, access, and destruction processes. Evidence: encryption configuration, key inventory, exceptions. Test representative endpoints, databases, backups, and interfaces.

13. Secure configuration and change control

Establish secure baselines, configuration ownership, approval workflows, segregation of duties, rollback procedures, and emergency-change review. Evidence: baseline standards, configuration scans, change tickets, approvals. Test systems for drift and unauthorized change.

14. Vulnerability management

Identify, prioritize, remediate, and verify vulnerabilities according to risk. Define scan coverage, authenticated scanning expectations, severity-to-SLA mapping, exception criteria, and risk escalation. Evidence: scan reports, remediation tickets, exception records. Test overdue vulnerabilities and recurrence patterns.

15. Secure development and application controls

Integrate security into requirements, design, development, testing, deployment, and maintenance for applications handling customer information. Include code review, dependency management, secrets handling, threat modeling, security testing, and release approval. Evidence: SDLC records, SAST/DAST results, dependency reports, release gates.

16. Logging, monitoring, and anomaly detection

Collect and protect logs needed to detect unauthorized access, misuse, anomalous activity, control failures, and incidents. Define time synchronization, retention, alert ownership, escalation, and use-case tuning. Evidence: logging standard, SIEM coverage, alert records, retention settings. Test end-to-end detection for selected scenarios.

17. Incident response and escalation

Maintain procedures for identification, triage, containment, eradication, recovery, evidence preservation, communications, and post-incident improvement. Assign legal and regulatory notification decision ownership. Evidence: incident plan, exercises, incident records, lessons learned. Test through tabletop exercises covering customer-information compromise.

18. FTC notification-event decision workflow

Maintain a documented decision workflow for events potentially meeting the Safeguards Rule notification boundary. Preserve the currently verified boundary that notification analysis includes whether an event involves acquisition of unencrypted customer information without authorization, the applicable threshold of at least 500 consumers, and the currently verified no-later-than-30-days notification timing requirement. Do not generalize these conditions outside the FTC rule. Evidence: decision worksheet, legal review, consumer count basis, notification record. Reverify current regulatory text before release and whenever an incident occurs.

19. Business continuity and resilience interfaces

Identify dependencies between safeguards and continuity capabilities, including identity, logging, key management, secure backups, alternate communications, and recovery sequencing. Evidence: BIA linkage, recovery plans, exercise results. Test that recovery does not bypass security controls without documented emergency authorization.

20. Service-provider due diligence

Assess service providers that receive, maintain, process, or access customer information. Evaluate security capability, relevant control evidence, incidents, financial/operational resilience, subcontracting, and concentration risk. Evidence: due-diligence package, risk rating, approvals, remediation commitments.

21. Contractual safeguards and oversight

Use contract provisions appropriate to the relationship to require safeguards and support oversight. Track security obligations, incident notification terms, audit/evidence rights, data-return/destruction terms, and subcontractor requirements. Evidence: executed agreements, obligation register, review calendar. Test selected vendors for contractual compliance and ongoing monitoring.

22. Cloud and shared-responsibility controls

Map customer-information safeguards across provider and customer responsibilities for IaaS, PaaS, and SaaS. Document identity, logging, encryption, configuration, backup, network, and incident responsibilities. Evidence: shared-responsibility matrix, cloud configuration evidence, provider assurance. Test for control gaps created by assumed provider responsibility.

23. Workforce security and training

Implement role-appropriate security awareness and specialized training for administrators, developers, incident responders, service-provider managers, and other high-risk roles. Evidence: curriculum, completion records, role mappings, exercises. Test training coverage and effectiveness using scenario or phishing metrics where appropriate.

24. Physical safeguards

Protect facilities, devices, media, and restricted areas through access controls, visitor management, environmental protections, secure storage, and disposal practices proportional to risk. Evidence: access logs, visitor records, facility assessments, media handling records. Test physical access revocation and restricted-area controls.

25. Data retention and secure disposal

Define retention periods based on legal, regulatory, contractual, operational, and risk requirements and dispose of customer information securely when no longer required. Evidence: retention schedule, deletion jobs, media destruction certificates, legal-hold exceptions. Test selected repositories for over-retention and disposal completion.

26. Control testing and continuous monitoring

Establish a testing program for safeguards using evidence review, technical validation, sampling, control self-assessment, independent testing where appropriate, and continuous monitoring. Evidence: test plans, workpapers, findings, metrics. Ensure testing frequency reflects control criticality and change rate.

27. Penetration testing and vulnerability-assessment governance

Define governance for penetration testing and vulnerability assessment consistent with the current Safeguards Rule and organizational risk. Specify scope, independence/competence, remediation tracking, retest expectations, and exception handling. Evidence: test reports, remediation plans, retest results. Reverify current FTC requirements before release.

28. Management and governing-body reporting

Provide periodic reporting on risk posture, material control deficiencies, incidents, service-provider risks, remediation, testing, and program changes to appropriate senior governance. Evidence: reports, meeting minutes, action registers. Test that material issues are escalated and tracked to resolution.

29. Exceptions, risk acceptance, and remediation

Use a controlled exception process that records rationale, compensating safeguards, residual risk, accountable approver, expiration, and remediation plan. Evidence: exception register, approvals, review dates. Test for expired exceptions and repeated extensions without risk reassessment.

30. Evidence architecture and audit readiness

Define evidence objects for each safeguard, naming conventions, repositories, retention, chain-of-custody where needed, and ownership. Maintain evidence-to-control mappings and distinguish operational evidence from management assertion. Evidence: evidence catalog, control matrix, workpapers. Test that sampled controls can be independently reconstructed from retained evidence.

31. Change triggers, amendment watch, and reassessment

Monitor FTC rule amendments, official guidance, enforcement developments relevant to scope, and organizational changes that could affect applicability or safeguards. Trigger reassessment after material technology, data, vendor, product, business-model, or regulatory changes. Evidence: source-watch log, change assessments, updated risk records.

32. Localization, provenance, artifact QA, and release controls

Freeze the exact English source before controlled es-419 and pt-BR localization. Bind each localization to the frozen English identity and preserve regulatory meaning without presenting unofficial translations as authoritative FTC text. Before publication require trilingual parity, rendered/page QA, accessibility checks, exact SHA-256 artifact identities, durable staging, workflow-security checks, source-state reverification, predecessor publication, and release-registry/catalog reconciliation. No publication claim is permitted until those gates are evidenced on the exact candidate.

Controlled release boundary

This development master does not itself establish compliance, legal interpretation, audit assurance, or publication eligibility. Release requires exact-candidate evidence under the repository anti-halt process and must preserve any explicitly documented non-delegable human review requirement.